MAPA RESUMEN · PERÚ

Nuevo Reglamento de la Ley de Protección de Datos Personales

Ley N° 29733 · D.S. N° 016-2024-JUS

Publicado el 30/11/2024 · Deroga el D.S. N° 003-2013-JUS

VISIÓN GENERAL

Cinco pilares del Reglamento

01 **Ámbito y consentimiento**
Quién está obligado y cómo se autoriza el uso de datos.

02 **Transferencias y terceros**
Flujo transfronterizo y proveedores tecnológicos.

03 **Obligaciones**
Incidentes, Oficial de Datos y medidas de seguridad.

04 **Derechos del titular**
Acceso, portabilidad, oposición y tutela.

05 **Sanciones y vigencia**
Infracciones, multas y cronograma de adecuación.

01 · ÁMBITO DE APLICACIÓN

A quién obliga el Reglamento

Aplica a

Toda modalidad de tratamiento de datos personales efectuado por personas naturales, entidades públicas o instituciones del sector privado, cuando:

1. Sea efectuado en un establecimiento ubicado en territorio peruano.
2. Sea efectuado por un encargado del tratamiento, con independencia de su ubicación, a nombre de un titular de banco de datos establecido en territorio peruano.
   Ej.: una clínica de Lima que contrata un call center en Colombia.
3. El titular del banco de datos no se encuentre establecido en territorio peruano, pero utilice medios situados en dicho territorio.
   Ej.: una tienda online extranjera que vende a clientes en Perú.

No aplica a

- Personas naturales, para fines domésticos, personales o relacionados con su vida privada o familiar
- Bancos de datos de la administración pública usados solo para defensa nacional, seguridad pública o investigación y represión del delito

01 · CONSENTIMIENTO

Cuatro requisitos para que sea válido

Libre
Sin presión ni condicionar servicios a datos no indispensables.

Previo
Antes de recolectar o de cambiar la finalidad.

Expreso e inequívoco
Verbal, escrito o digital.

Informado
Finalidad, destinatarios, plazo y derechos.

Datos sensibles (datos íntimos, como salud, genética, biometría, vida afectiva o afiliación sindical): el consentimiento debe otorgarse por escrito, mediante firma manuscrita, digital, electrónica o cualquier otra modalidad que garantice la voluntad del titular.

Revocación: el titular de los datos personales puede revocar su consentimiento en cualquier momento, y su atención debe darse en un plazo máximo de 10 días.

Transferencia de Datos Personales y Tratamiento Especial

Transferencia

- Requiere el consentimiento del titular y debe informársele.
- La transferencia nacional debe poder demostrar que se comunicó al receptor las condiciones del consentimiento.

Flujo transfronterizo

- Solo a países con nivel adecuado de protección
- Si no lo tienen: garantías, como cláusulas contractuales modelo u otros instrumentos jurídicos

Proveedores y encargados

- Confidencialidad, integridad y disponibilidad
- Evidenciar la supresión al terminar el servicio
- Conservación máxima: **2 años**

Niños y adolescentes

- El tratamiento de datos de niños, niñas y adolescentes es lícito cuando se obtiene el consentimiento de quien ejerce la patria potestad o tutela.
- Los mayores de 14 y menores de 18 años pueden otorgar su consentimiento, siempre que la información se haya expresado en un lenguaje comprensible para ellos.
- Prohibido obtener datos de la familia a través del menor

03 · INCIDENTES DE SEGURIDAD

48 h

para notificar a la Autoridad Nacional

Cuándo: grandes volúmenes, muchos afectados, datos sensibles o perjuicio evidente.

Qué informar: naturaleza, contacto del Oficial, consecuencias y medidas.

A quién más: al titular afectado y, si es digital, al Centro Nacional de Seguridad Digital.

03 · OFICIAL DE DATOS PERSONALES

Designación del Oficial de Datos Personales

El titular del banco de datos personales o responsable debe designar un Oficial de Datos Personales cuando:

1. El tratamiento lo realiza una **entidad pública**.

2. El titular del banco de datos realiza tratamientos de **grandes volúmenes** de datos personales, en cantidad o tipo de datos, o que puedan afectar a un gran número de personas.

3. El titular del banco de datos realiza actividades principales o de **giro de negocio** que comprendan el tratamiento de datos sensibles.

Perfil y funciones

- Interno o externo, sin exclusividad
- Se comunica a la Autoridad en 15 días
- Asesora, verifica y capacita

03 · SEGURIDAD

Medidas de seguridad

Accesos

Gestión desde el registro del usuario hasta su baja, incluidas vacaciones o permisos esporádicos.

Trazabilidad

Registros de interacción con los datos, conservados por un mínimo de 2 años.

Documento de Seguridad

Aprobado y con fecha cierta. Incluye gestión de accesos, de privilegios y su verificación periódica. Ref.: NTP-ISO/IEC 27001.

Áreas seguras

- Perímetros de seguridad
- Ingreso solo para personal autorizado
- Sistemas contra desastres naturales, ataques maliciosos o accidentes

Equipos seguros

Dentro y fuera de las instalaciones:

- Ubicación y protección de equipos
- Protección contra fallas eléctricas
- Protección del cableado contra interceptación, interferencia o daño

Respaldo y recuperación

Copias de respaldo seguras y continuas, con verificación de su integridad. Ref.: NTP-ISO/IEC 27001:2022.

04 · DERECHOS DEL TITULAR

Qué puede exigir el ciudadano

Los derechos de información, acceso, rectificación, cancelación, oposición y tratamiento objetivo solo pueden ser ejercidos por el **titular de los datos personales**.

Derecho	Plazo
Información	8 días
Acceso y portabilidad	20 días
Rectificación, cancelación, oposición	10 días

Requisitos de la solicitud

- El ejercicio de los derechos se lleva a cabo mediante solicitud dirigida al titular del banco de datos personales, que debe dejar constancia de su recepción.
- Si no cumple los requisitos, en 5 días el titular del banco de datos formula las observaciones, invitando al titular a subsanarlas dentro de un plazo máximo de 5 días.
- El titular del banco de datos debe establecer un procedimiento sencillo para ejercer los derechos.

Lo nuevo

- Portabilidad de datos
- Desindexación en internet
- No ser objeto de decisiones automatizadas

Tres niveles de infracción

Entre las principales infracciones tenemos:

Leves

No designar Oficial, no inscribir bancos de datos, atender fuera de plazo.

Graves

Tratar sin consentimiento válido, no notificar incidentes.

Muy graves

Medios fraudulentos, información falsa a la Autoridad.

Pronto pago: 40% de descuento. Multas coercitivas de hasta 100 UIT.

05 · VIGENCIA

Oficial de Datos: adecuación progresiva

Fecha de entrada en vigor de la obligación, según ventas anuales del titular del banco de datos, responsable o encargado:

30 nov. 2025	Ventas anuales superiores a 2300 UIT
30 nov. 2026	Medianas: 1700 a 2300 UIT
30 nov. 2027	Pequeñas: 150 a 1700 UIT
30 nov. 2028	Microempresas: hasta 150 UIT y otros equivalentes

⚠ Si la organización está obligada a tener un ODP y no cumple con su designación, comete una **infracción leve** sancionable con hasta **5 UIT**.

¿Tu organización ya empezó a adecuarse?

Revisa consentimientos, contratos con proveedores, el protocolo de incidentes y si te corresponde designar un Oficial de Datos Personales.